SOX IT GENERAL CONTROLS ASSESSMENT

Logical Access Management — Control ITGC-01

Independent Cybersecurity & GRC Portfolio Project

Prepared by: Christopher Davis, CISA
Assessment Environment: Active Directory Lab — `lab.local`
Simulated Application: FinanceLedger
Assessment Date: October 30–31, 2026
Final Control Status: Remediated — Retest Passed
Classification: Simulated Assessment / Educational Portfolio

---

1. Executive Summary

An independent, simulated Sarbanes-Oxley (SOX) IT General Controls assessment was performed to evaluate logical access management within a fictional financial reporting environment.

The assessment focused on whether membership in the Active Directory security group `GG_FinanceLedger_Users` matched a simulated management-approved access register.

The initial assessment identified one unauthorized group membership among four direct group members reviewed.

The exception involved an HR user, Ethan Murphy, who was included in the FinanceLedger access group despite being designated as unauthorized in the simulated approval register.

The exception was deliberately introduced to demonstrate the identification, documentation, remediation, and retesting of an access-control deficiency.

Following the initial assessment, the unauthorized membership was removed. A subsequent PowerShell export confirmed that the three remaining direct group members matched the simulated approved-access register.

Assessment Results

Metric	Result
Control tested	ITGC-01 — Logical Access Management
Initial group memberships reviewed	4
Initial exceptions identified	1
Initial exception rate	25%
Remediation performed	Unauthorized membership removed
Post-remediation memberships reviewed	3
Remaining membership discrepancies	0
Final retest result	PASS
Final finding status	Remediated — Retest Passed (Simulated)

Overall conclusion: The initial test identified one simulated authorization discrepancy. Remediation was performed, and subsequent testing found no discrepancies among the three remaining direct group memberships.

This conclusion is limited to the specific Active Directory group membership tested.

---

2. Assessment Background

The assessment was conducted in an independent Active Directory lab designed to simulate access controls supporting a fictional financial reporting application called FinanceLedger.

For the purposes of the exercise, membership in `GG_FinanceLedger_Users` represented authorized access to the fictional application.

The project demonstrates ITGC testing techniques relevant to environments where technology controls support internal control over financial reporting.

Important limitation: FinanceLedger is a simulated application. The assessment does not establish that the Active Directory group controls access to an actual financial reporting system.

This project is not a formal SOX audit or an opinion on the effectiveness of internal control over financial reporting.

---

3. Assessment Objectives

The assessment was designed to:

1. Identify the users assigned to the FinanceLedger access group.
2. Compare actual Active Directory group membership against a simulated approved-access register.
3. Identify memberships lacking documented simulated authorization.
4. Document an access-control exception using an audit workpaper.
5. Perform corrective action within the lab.
6. Retest group membership after remediation.
7. Preserve evidence supporting the initial finding and subsequent retest.

---

4. Assessment Scope

In Scope

- Active Directory domain: `lab.local`
- Organizational unit: `Corp → Groups`
- Security group: `GG_FinanceLedger_Users`
- Direct user memberships
- Simulated approved-access register
- PowerShell membership exports
- Exception documentation
- Remediation and post-remediation verification

Out of Scope

- Actual financial reporting applications
- Effective permissions to application resources
- Nested group membership analysis
- Historical access approvals
- User provisioning and termination timeliness
- Privileged access testing
- Change management controls
- Enterprise-wide SOX compliance

- Financial statement assertions

The scope was intentionally limited to demonstrate one logical access-control test from beginning to end.

---

5. Risk and Control Matrix

Field	Description
Control ID	ITGC-01
Control Name	FinanceLedger Logical Access Control
Control Domain	Logical Access Management
Business Risk	Unauthorized users may obtain access to financially relevant resources
Control Objective	Restrict FinanceLedger group membership to authorized personnel
Control Type	Preventive access restriction
Test Type	Inspection and comparison
Population	Four direct group memberships at initial testing
Evidence	Simulated approval register and Active Directory membership export
Initial Result	Exception Identified
Final Retest Result	PASS

Control Description

Access to the simulated FinanceLedger environment is represented by membership in the designated Active Directory security group.

Authorized membership is determined by comparison against a simulated management-approved access register.

Any group member without corresponding authorization represents a potential logical access-control exception requiring investigation.

---

6. Assessment Methodology

The following testing procedures were performed.

Procedure 1 — Identify Access Population

The `GG_FinanceLedger_Users` security group was inspected using Active Directory Users and Computers.

The initial group membership contained three users designated as authorized in the simulated scenario:

- Amelia Green
- Ava Thompson
- Benjamin Hall

An additional account, Ethan Murphy, was deliberately added to create a simulated unauthorized-access exception.

Procedure 2 — Obtain Authorization Criteria

A simulated approved-access register was created to identify which users should have FinanceLedger access.

The register designated Amelia Green, Ava Thompson, and Benjamin Hall as authorized.

Ethan Murphy was designated as an HR employee without approved FinanceLedger access.

Procedure 3 — Export Actual Membership

PowerShell was used to extract the current Active Directory group membership.

The following command was used:

```
None
Get-ADGroupMember -Identity "GG_FinanceLedger_Users" |
    Select-Object Name, SamAccountName, ObjectClass |
    Export-Csv
"C:\Users\Public\SOX_ITGC-01_E04_FinanceLedger_Actual_Group_Members
hip.csv" -NoTypeInformation
```

The resulting export contained four direct user memberships.

Procedure 4 — Compare Authorization Against Actual Membership

The exported group membership was compared against the simulated approved-access register.

One discrepancy was identified.

Procedure 5 — Document the Finding

The exception was recorded in the ITGC-01 control-testing workpaper, including its condition, criteria, potential risk, and recommended corrective action.

Procedure 6 — Perform Remediation

Ethan Murphy was removed from `GG_FinanceLedger_Users`.

Procedure 7 — Retest

A new PowerShell export was generated after remediation.

The post-remediation membership was compared against the simulated authorization register to verify that the identified discrepancy had been resolved.

---

7. Initial Control Testing Results

Employee	Simulated Department	Approved Access	Actual Group Membership	Result
Amelia Green	Finance	Yes	Yes	PASS
Ava Thompson	Finance	Yes	Yes	PASS
Benjamin Hall	Finance	Yes	Yes	PASS
Ethan Murphy	HR	No	Yes	EXCEPTION

Initial Testing Conclusion

Three of the four direct group memberships matched the simulated approved-access register.

Ethan Murphy was identified as an exception because the account belonged to `GG_FinanceLedger_Users` without corresponding simulated authorization.

Initial result: EXCEPTION IDENTIFIED

The discrepancy was intentionally created for this training assessment.

---

8. Audit Finding

FIND-ITGC-01 — Simulated Unauthorized FinanceLedger Group Membership

Control: ITGC-01 — Logical Access Management

Condition

Ethan Murphy was a member of `GG_FinanceLedger_Users` despite not being authorized in the simulated approved-access register.

Criteria

Membership in the FinanceLedger access group should be restricted to users with documented authorization.

Cause

The membership was deliberately introduced for the simulation. No real-world operational root cause was established.

Risk

Unauthorized group membership could permit access to financially relevant resources if the group controls those permissions.

Such access could increase the risk of unauthorized viewing or modification of sensitive information.

Recommendation

Investigate membership discrepancies, confirm whether appropriate authorization exists, and remove unauthorized access when necessary.

Organizations should also maintain documented access approvals and periodically review membership in security groups supporting financially relevant systems.

Initial Finding Status

Open — Simulated Exception Identified

---

9. Remediation Activities

The identified exception was remediated by removing Ethan Murphy from the `GG_FinanceLedger_Users` security group.

The corrected membership was inspected in Active Directory Users and Computers.

The group subsequently contained:

- Amelia Green
- Ava Thompson
- Benjamin Hall

Remediation evidence: E06

The initial finding and supporting evidence were retained rather than overwritten.

---

10. Post-Remediation Testing

Retest Objective

Determine whether the previously identified unauthorized direct group membership remained after remediation.

Retest Procedure

Re-export direct membership of `GG_FinanceLedger_Users` using PowerShell and compare the results against the simulated approved-access register.

Retest Evidence

A new CSV export was generated and reviewed.

Retest evidence: E07

Retest Results

Employee	Approved Access	Post-Remediation Membership	Result
Amelia Green	Yes	Yes	PASS
Ava Thompson	Yes	Yes	PASS
Benjamin Hall	Yes	Yes	PASS
Ethan Murphy	No	No	PASS

Retest date: October 31, 2026

Retest conclusion: PASS — No discrepancies identified among the three remaining direct group memberships.

Final finding status: Remediated — Retest Passed (Simulated)

The successful retest does not erase the original exception. Both the initial finding and remediation result remain part of the assessment record.

---

11. Evidence Register

Evidence ID	Description	Purpose
E01	Initial FinanceLedger Group Membership	Establish initial authorized-user membership
E02	Simulated Unauthorized Group Membership	Document introduction of the access exception
E03	Simulated Approved-Access Register	Establish authorization criteria
E04	Pre-Remediation PowerShell Membership Export	Document actual membership population
E05	Logical Access Control-Testing Workpaper	Record testing, finding, and remediation results

E06	Active Directory Remediation Screenshot	Document removal of unauthorized membership
E07	Post-Remediation PowerShell Verification	Support successful membership retest

The evidence package includes screenshots, spreadsheet workpapers, and PowerShell-generated CSV files.

---

12. Assessment Limitations

The following limitations apply:

Simulated environment: All testing was performed in an independent lab rather than a production financial reporting environment.

Fictional authorization: The approved-access register represents simulated management authorization and was not obtained from an actual business owner.

Limited testing population: The assessment examined four initial direct group memberships.

Limited access testing: The assessment did not validate every potential path to effective application or resource access.

No operating-effectiveness conclusion: A single point-in-time test does not establish that an access-control process operated effectively throughout a reporting period.

No formal SOX opinion: The results cannot establish organizational SOX compliance or determine whether an ICFR deficiency constitutes a significant deficiency or material weakness.

---

13. Final Assessment Conclusion

The simulated SOX ITGC assessment successfully demonstrated a complete logical access-control testing workflow.

The initial test identified one membership that did not match the simulated authorization register.

The exception was documented in an audit workpaper, corrective action was performed, and post-remediation verification confirmed that the identified direct membership discrepancy had been resolved.

The final retest passed within the defined scope.

This project demonstrates practical familiarity with:

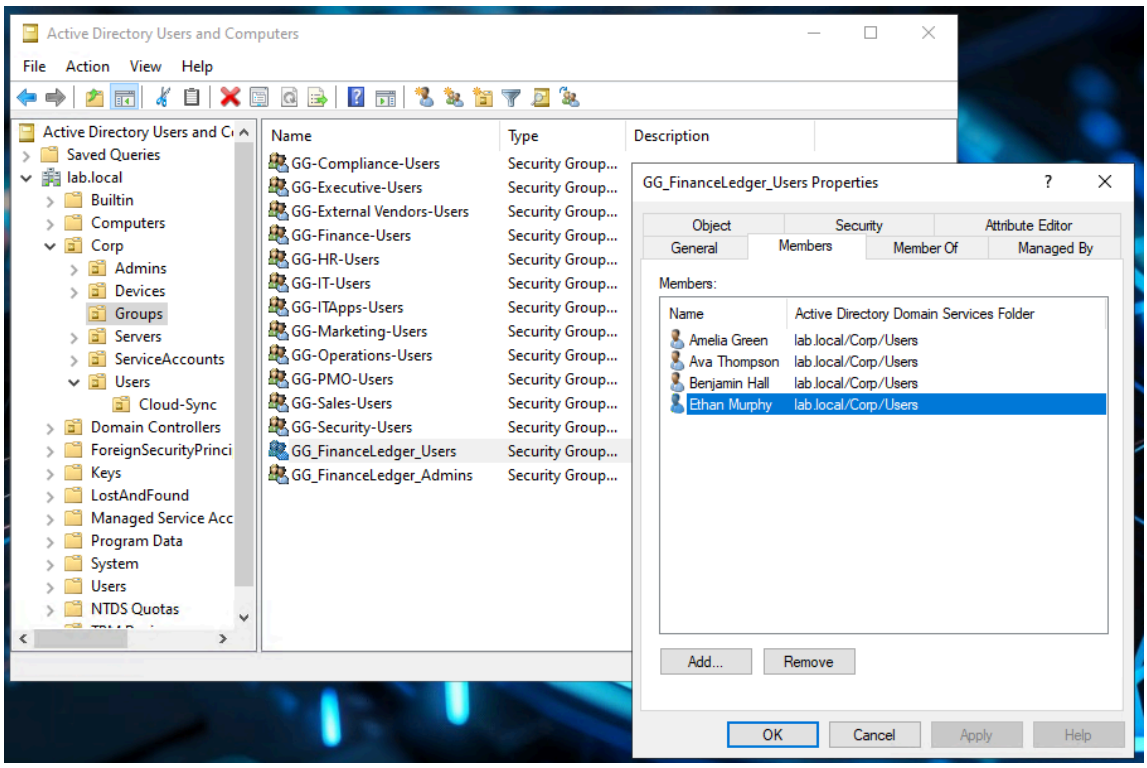
- ITGC control objectives
- Logical access risk identification
- Evidence collection and analysis
- Active Directory access reviews
- PowerShell-based control testing
- Audit finding documentation
- Remediation tracking
- Post-remediation verification
- Evidence traceability

The project provides an educational example of how technical access-management knowledge can support GRC and technology audit activities.

Prepared by: Christopher Davis, CISA
Project Type: Independent Simulated SOX ITGC Assessment
Assessment Period: October 30–31, 2026
Final Status: Remediated — Retest Passed (Simulated)

End of Report

Appendix



SOX_ITGC-01_E02_FinanceLedger_Unauthorized_Access_Exception

SOX_ITGC-01_E03_FinanceLedger_Approved_Access_Register

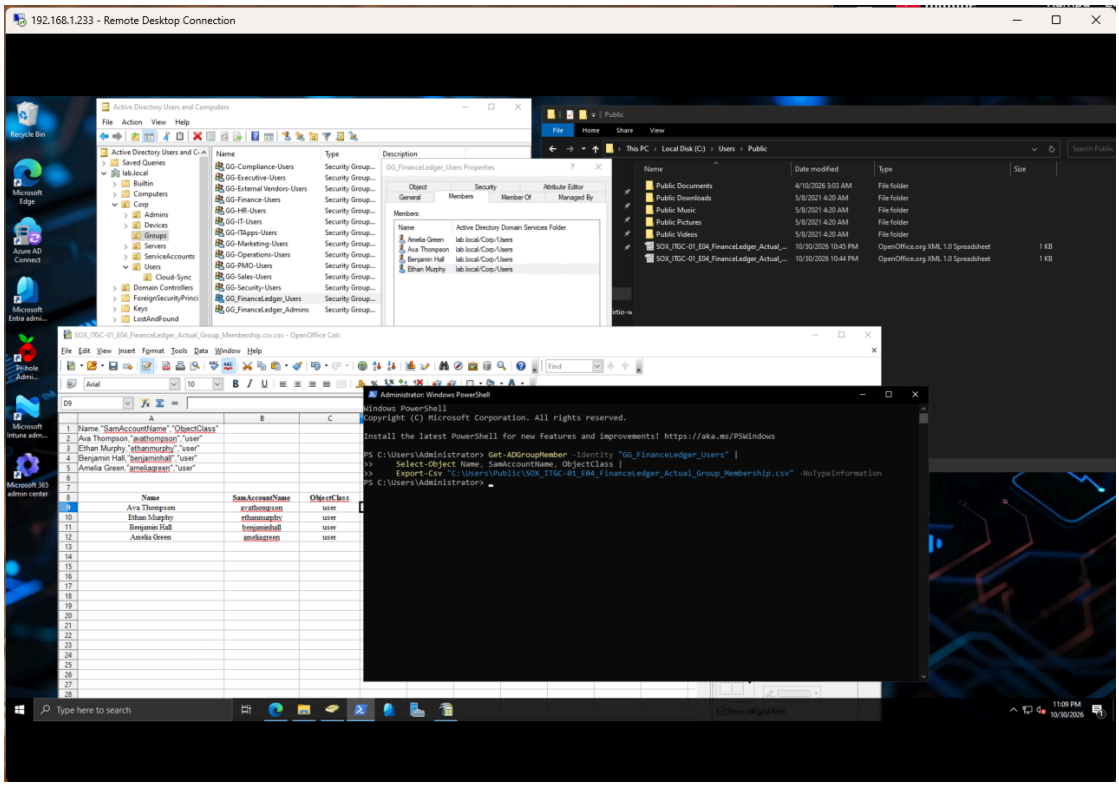
File Edit View Insert Format Data Tools Extensions Help

Menus 100% $ % .0 .00 123 Defaul... 10 B

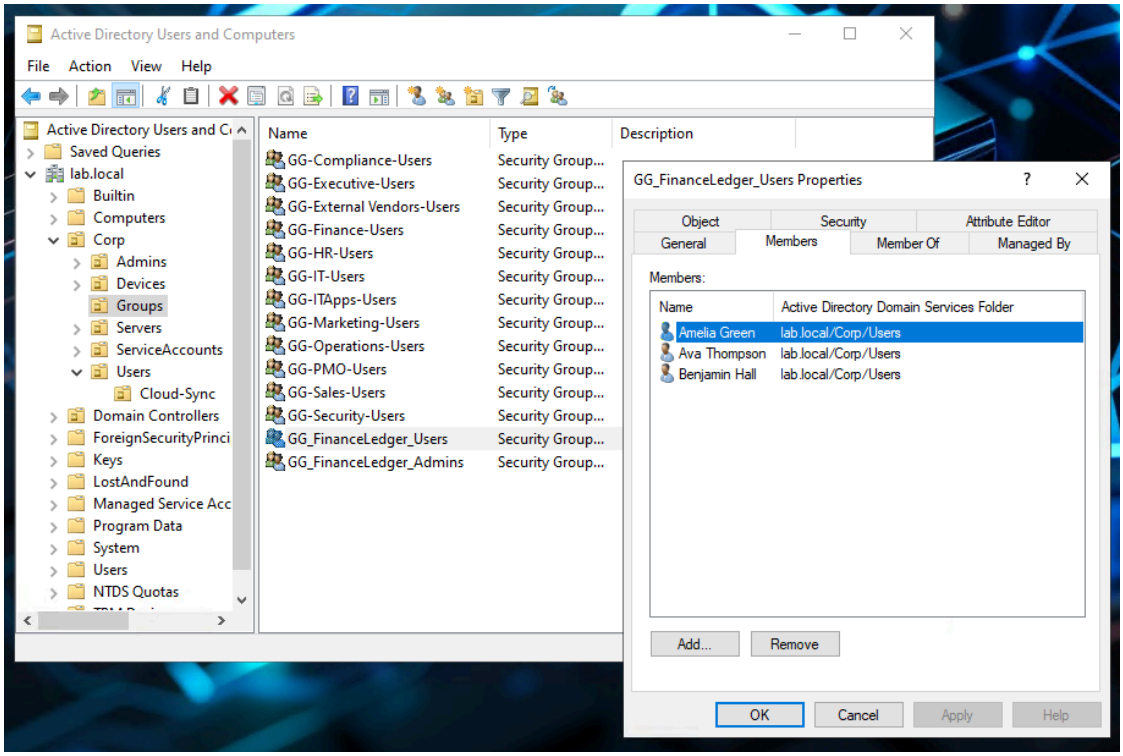
C8

	A	B	C	D	E	F
1	**Employee**	**Department**	**FinanceLedger Access Approved**			
2	Amelia Green	Finance	Yes			
3	Ava Thompson	Finance	Yes			
4	Benjamin Hall	Finance	Yes			
5	Ethan Murphy	HR	No			
6						
7						
8						
9						
10						
11						
12						
13						

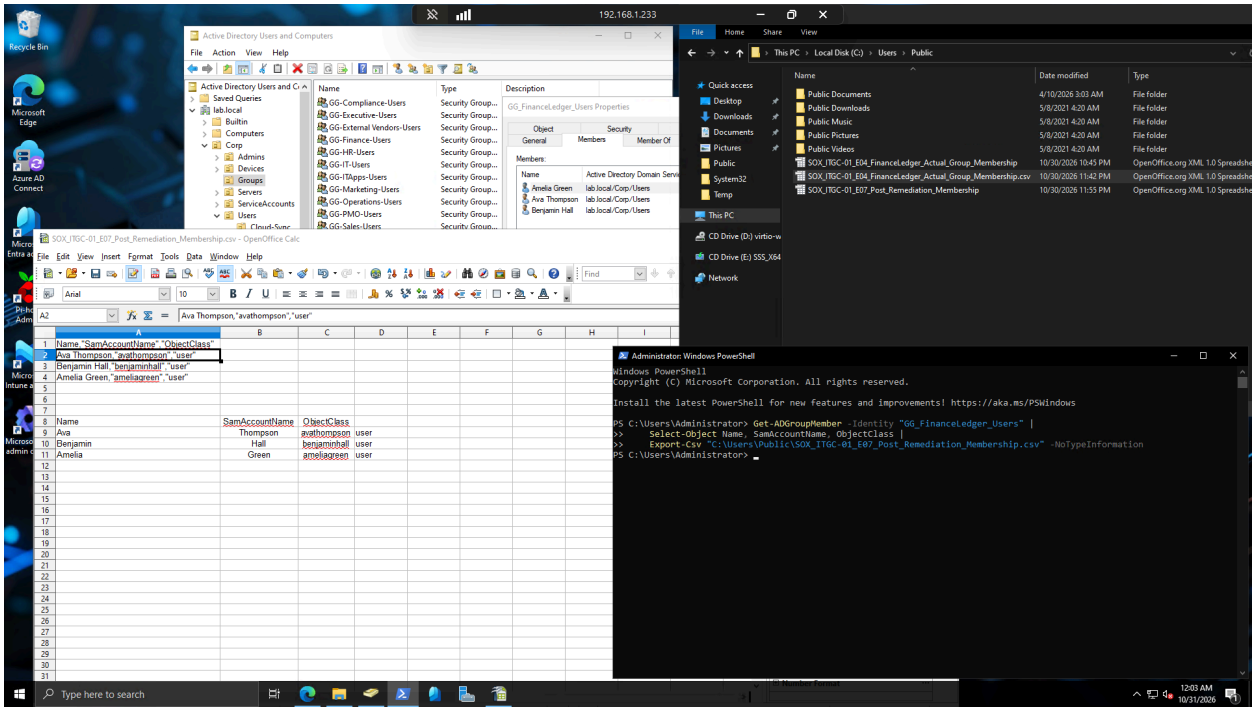
SOX_ITGC-01_E03_FinanceLedger_Approved_Access_Register



SOX_ITGC-01_E04_FinanceLedger_Actual_Group_Membership



SOX_ITGC-01_E06_FinanceLedger_Access_Remediation



SOX_ITGC-01_E07_Post_Remediation_Verification

Download: [Supporting workpapers]

Linkedin: www.linkedin.com/in/christopher-davis-cisa-3707a150